

SOFTWARE REQUIREMENTS SPECIFICATION

Software Requirements Specification (SRS)

OneLogin – Single Sign-On Rollout Across a University's Applications

Comprehensive IEEE 830-style specification governing the single sign-on (SSO) identity service. Establishes functional requirements, measurable non-functional targets, stakeholder elicitation findings, MoSCoW prioritization, external interface boundaries, and an end-to-end Requirements Traceability Matrix linking all requirements to verification test cases.

Document Control

Document Title	Software Requirements Specification — OneLogin SSO
Document Version	Version 1.0 (Baseline)
Standard Followed	IEEE Std 830-1998 Recommended Practice for Software Requirements Specifications
Status	Baseline for Design, Planning, Estimation, and Test Derivation
Prepared For	Vice-Chancellor, IT Head, Application Owners, IT Helpdesk, Engineering Team
Related Deliverables	UML Package, Project Plan, Estimation Sheet, Test Plan & Evidence, Risk Register & Closure Note

Formal Sign-Off & Approvals

Role	Designation & Stakeholder	Signature	Approval Date
Project Sponsor	Vice-Chancellor	_____	02 Oct 2026
Business Owner	IT Head	_____	02 Oct 2026
Project Manager	Lead SEPM Consultant	_____	02 Oct 2026
Lead Engineer	Lead Systems Engineer	_____	02 Oct 2026

Baseline Governance Policy: This document represents the authoritative functional and non-functional baseline for the OneLogin SSO rollout. All downstream architecture, critical path schedules, numerical estimation formulas, test cases, and risk mitigation strategies are directly derived from and traceable to this specification.

1. Introduction

1.1 Purpose

This document specifies the requirements for OneLogin, a single sign-on (SSO) service that lets students and staff of the university authenticate once and use all integrated applications. It is written for the Vice-Chancellor and IT Head (approval), the two project engineers (design and build), application owners (integration), the IT helpdesk (operations), and the test team (verification). Every requirement is uniquely identified, prioritized with MoSCoW, and, for non-functional requirements, given a measurable target.

1.2 Scope and Business Justification

Students and staff currently use 12 separate applications (ERP, LMS, library, email, placement, hostel, and others), each with its own password. The IT helpdesk handles 1,400 password-reset requests a month. The IT head wants single sign-on across all 12 applications, and the Vice-Chancellor wants it live before the next semester, 16 weeks away. The 12 applications fall into three groups, which drive both the requirements and the effort:

Application Group	Count	Characteristic	Integration Effort	Treatment
Cloud Products	4	Support standard login protocols	3 days each	MUST (FR-03)
In-House Applications	5	Owned by the university; can be modified	8 days each	MUST (FR-04)
Old Vendor Products	3	No native SSO support	15 days each (if possible)	SHOULD (FR-05)

Business Goals (Measurable)

- **One login for integrated applications:** A user logs in once and reaches every application their role permits (verified by TC-03).
- **Cut helpdesk load:** Baseline: 1,400 resets × 12 minutes = 16,800 minutes = 280 helpdesk hours per month. If resets fall by 75% (to 350 requests), 210 hours per month are saved and 70 hours remain.
- **Deliver before the next semester (16 weeks):** Maintain rigorous operational security with no weakening of access controls.

Scope Decision Summary: Nine applications (4 cloud + 5 in-house) are the committed baseline. The three vendor applications are a Should: they need an adapter whose feasibility is unproven, and they carry the highest effort (15 days each). The full effort and duration comparison of the two options, with justification, is in the Estimation Sheet.

Out of Scope: Replacing the authorization logic inside each application, migrating application data, social or third-party login, passwordless or biometric login.

1.3 Definitions, Acronyms and Abbreviations

Term	Meaning
SSO	Single sign-on: one authentication grants access to multiple applications
IdP	Identity provider: the central OneLogin service that authenticates users and issues assertions/tokens
SP / Application	Service provider: any of the 12 university applications that relies on the IdP
SAML 2.0 / OIDC	Standard federation protocols (Security Assertion Markup Language; OpenID Connect over OAuth 2.0)
RBAC / MFA	Role-based access control / Multi-factor authentication
MoSCoW	Must / Should / Could / Won't have prioritization framework
RTO / RPO	Recovery time objective / Recovery point objective

2. Overall Description

2.1 Product Perspective

OneLogin is a new, central identity layer placed in front of the 12 existing applications. It does not replace those applications; it takes over authentication from them. Cloud and in-house applications trust OneLogin through SAML 2.0 or OIDC. Vendor applications that cannot do so are reached, where feasible, through an adapter. Authorization inside each application remains with that application, but OneLogin decides which applications each role may open.

2.2 Product Functions (Summary)

- Authenticate users centrally and create an SSO session (FR-01, FR-02).
- Federate cloud, in-house, and (if feasible) vendor applications (FR-03, FR-04, FR-05).
- Enforce role-based access and role administration (FR-06).
- Provide self-service password reset (FR-07), failed-login lockout (FR-08), and session timeout (FR-09).
- Record an audit trail (FR-10) and require MFA for privileged roles (FR-11).

2.3 User Classes and Stakeholders

User Class	Description	Main Needs
Student	Largest user group; uses LMS, library, email, placement, hostel	One login; quick self-service reset; works on any device
Staff / Faculty	Uses ERP, LMS, email, and administrative applications	One login; stable sessions; correct access to staff-only applications
IT Helpdesk Agent	Handles 1,400 reset requests a month today	Fewer reset tickets; ability to unlock accounts; verification tools
Application Owner	Responsible for one or more of the 12 applications	Clear integration method; minimal change to application; usage visibility
IT Administrator	Operates OneLogin; assigns roles; reviews logs	Role administration; audit logs; monitoring; recovery
IT Head / VC	Executive Sponsors	Single sign-on for all 12 applications by the next semester, justified and secure

2.4 Operating Environment

OneLogin runs on university-managed infrastructure with active-standby redundancy. Users reach it through current versions of common web browsers on desktops, laptops, and mobile phones, on campus or off campus over HTTPS.

2.5 Constraints

ID	Constraint	Specification
C-01	Time	Go-live before the next semester, 16 weeks away (80 working days on a 5-day week).
C-02	Team	2 engineers are available for integration work.
C-03	Technology	3 vendor products lack SSO; 4 cloud products support standard protocols; 5 applications are in-house.
C-04	Effort Data	Fixed case rates: 3 days (cloud), 8 days (in-house), 15 days (vendor, if possible) per app. No other figures invented.
C-05	Security / SPOF	A single login creates a single point of failure; availability and recovery targets (FR-01, FR-04) are mandatory.

2.6 Assumptions and Dependencies

ID	Assumption / Dependency	Impact If False
A-01	A working week has 5 days; 16 weeks = 80 working days	Duration figures change
A-02	An authoritative user directory exists or can be built from ERP records	Add directory-build work to the plan
A-03	Every user has a verified secondary contact (registered email/mobile)	Self-service reset needs offline verification fallback
A-04	The 4 cloud applications support SAML 2.0 or OIDC	Their 3-day effort estimate is invalid
A-05	Application owners make teams available for integration testing	Schedule risk
A-06	The baseline of 1,400 resets/month comes from tickets and is representative	Benefit figures change

2.7 Requirements Elicitation: Sources & Derivation

Requirements were elicited through structured interviews and empirical analysis of operational forms and records:

Technique	Source	Focus of Enquiry	Derived Reqs
Interview	Students	How many passwords used; frequency forgotten; mobile tolerance	FR-01, FR-07, NFR-05
Interview	Staff / Faculty	Daily application sequence; timeout interruptions; access rights	FR-02, FR-06, FR-09
Interview	IT Helpdesk	Reset procedure; volume (1,400/mo, 12 min each); lockout handling	FR-07, FR-08, FR-10, FR-11
Interview	Application Owners	Hosting, login methods, protocol support, code modification ability	FR-03, FR-04, FR-05, NFR-06
Interview	IT Head, VC	Deadline, scope priority, outage and security tolerance	FR-11, NFR-01, NFR-04, MoSCoW
Document Analysis	Reset Request Forms	Fields used to verify identity today; common failure causes	FR-07, FR-08
Document Analysis	Ticket Spreadsheet	Reset volume per month; ticket categories; peak periods	Business goals, NFR-03
Document Analysis	App Inventory Sheet	Per app: type (cloud/in-house/vendor), login method, owner	FR-03, FR-04, FR-05
Document Analysis	User & Role Sheets	Role names, groups, who may use which application	FR-06

3. Specific Requirements

3.1 External Interface Requirements

- **User Interface:** Web login page; self-service reset pages; application launcher listing permitted applications; administrator console for roles, unlocks, and log review. Responsive across mobile and desktop.
- **Software Interfaces:** SAML 2.0 and OpenID Connect / OAuth 2.0 toward cloud and in-house apps; user directory read access (user ID, status, role, secondary contacts); adapter interface for vendor apps; SMS/email gateway.
- **Communications:** All authentication traffic over HTTPS using TLS 1.2+; signed assertions and tokens; NTP clock synchronization between IdP and applications.
- **Hardware:** University-managed servers or virtual machines with a standby instance (supports NFR-01 and NFR-04).

3.2 Functional Requirements (Part 1: Core Federation & Access)

Each requirement statement is atomic and testable. Acceptance criteria define the observable condition used to derive test cases.

ID	Requirement & Acceptance Criteria	Priority	Source
FR-01	Central Authentication: The system shall authenticate every user against a single central IdP using one user ID and one password. <i>Acceptance:</i> A valid pair yields an authenticated session; an invalid pair is rejected with a generic message that does not reveal which field was wrong.	MUST	Problem statement; IT Head
FR-02	SSO Session and Single Logout (SLO): After one successful login the system shall create an SSO session and give access to every integrated application the user's role permits without a further credential prompt. Logging out from the IdP or any integrated application shall end the session for all integrated applications. <i>Acceptance:</i> One login, then three applications (e.g., ERP, LMS, library) open with zero extra prompts; after logout, all three require login again.	MUST	Students, Staff
FR-03	Cloud Application Federation: The system shall federate the 4 cloud applications using SAML 2.0 or OIDC, issuing signed, time-limited assertions/tokens. <i>Acceptance:</i> Each cloud application accepts a valid assertion and rejects a tampered or expired one.	MUST	Application owners
FR-04	In-House Application Integration: The 5 in-house applications shall delegate authentication to the IdP through SAML 2.0 or OIDC, and their local login forms shall be disabled. <i>Acceptance:</i> An unauthenticated request is redirected to the IdP; the returned token is accepted; direct local login is not possible.	MUST	Application owners
FR-05	Vendor Application Integration: Where technically feasible, the system shall give single sign-on to the 3 vendor applications (no native SSO) through an integration adapter (e.g., reverse-proxy or credential-injection gateway). <i>Acceptance:</i> For each vendor application either SSO via adapter works, or the app is recorded as an exception with a documented reason and stays on its own login.	SHOULD	Application owners; IT Head
FR-06	Role-Based Access Control (RBAC): The system shall assign each user one or more roles (Student, Staff, IT Helpdesk Agent, Application Owner, IT Administrator) and shall allow or deny access to each application according to a role-application matrix. Only an IT Administrator may assign or change roles; a change shall take effect within 5 minutes. <i>Acceptance:</i> Every cell of the role-application matrix behaves as defined; a non-administrator's attempt to change a role is refused.	MUST	Staff; IT admin

Traceability Note: FR-01 through FR-04 and FR-06 form the mandatory foundation for Option A, allowing 9 campus systems to be secured without depending on unverified reverse-proxy adapters.

3.2 Functional Requirements (Part 2: Security & Workflows)

ID	Requirement & Acceptance Criteria	Priority	Source
FR-07	Self-Service Password Reset (SSPR): A user shall be able to reset their own password without helpdesk help after verifying identity with a one-time code sent to the registered secondary contact. The code is valid for 15 minutes and single-use. A new password shall have at least 10 characters with an upper-case letter, a lower-case letter, and a digit. The new password applies to every integrated application. <i>Acceptance:</i> Reset completes end to end with no helpdesk action; an expired (>15 min) or already-used code is rejected.	MUST	Helpdesk; Students
FR-08	Failed-Login Lockout: After 5 consecutive failed login attempts (configurable) the system shall lock the account for 15 minutes or until a helpdesk agent or administrator unlocks it. A successful login resets the counter to 0. <i>Acceptance:</i> Attempts 1–4 do not lock; attempt 5 locks; a correct password during lockout is still refused.	MUST	Helpdesk; IT admin
FR-09	Session Idle Timeout: The system shall end an SSO session after 30 minutes without activity and require re-authentication. <i>Acceptance:</i> Activity at minute 29 keeps the session; no activity through minute 30 ends it.	MUST	Staff; Security
FR-10	Audit Logging: The system shall record every login success, login failure, lockout, unlock, password reset, and role change with user ID, timestamp, source address, and application; records are kept for 12 months and viewable by an IT Administrator. Passwords and reset codes shall never be written to logs. <i>Acceptance:</i> Each event type produces one log record; log search shows zero secret values.	MUST	IT admin; Security
FR-11	MFA for Privileged Roles: The system shall require a second factor at login for the IT Helpdesk Agent and IT Administrator roles. <i>Acceptance:</i> A helpdesk or administrator login without the second factor is refused; a Student login does not prompt for one.	SHOULD	IT Head; Security

Role Permission Matrix for OneLogin Functions (Basis for FR-06 & Access Tests)

Function	Student	Staff	Helpdesk	App Owner	IT Admin
Log in and open permitted applications	Yes	Yes	Yes	Yes	Yes
Reset own password	Yes	Yes	Yes	Yes	Yes
Unlock another user's account	No	No	Yes	No	Yes
Trigger verified reset for another user	No	No	Yes	No	Yes
Assign or change roles	No	No	No	No	Yes
View audit log	No	No	Lock/unlock only	Own app only	All
Register or remove app in SSO	No	No	No	Request only	Yes

3.3 Non-Functional Requirements (Measurable Targets)

Targets are verified baseline metrics. Each requirement has a defined, repeatable measurement method so no requirement reads "the system shall be fast".

ID	Category	Requirement	Measurable Target	Measured By	Priority
NFR-01	Login Availability	IdP service shall be available whenever users need it.	≥ 99.9% per month (≤ 43.2 min unplanned downtime/month); planned maintenance announced 48h ahead excluded.	1-min synthetic probe; monthly report (TC-18)	MUST
NFR-02	Security	Credentials and sessions protected in transit and at rest.	(a) 100% traffic on TLS 1.2+; (b) salted hashes (bcrypt/Argon2); (c) cookies Secure/HttpOnly; (d) 0 Critical/High scan findings.	TLS scan, config review, vulnerability scan (TC-19)	MUST
NFR-03	Response Time	Login and application access feel immediate.	Credentials submitted to authenticated: ≤ 2.0s at p95; opening further app inside SSO adds ≤ 1.0s at p95 under peak load.	Load test with response-time report (TC-20)	MUST
NFR-04	Recoverability	IdP failure recoverable quickly with minimal data loss.	RTO ≤ 30 minutes; RPO ≤ 15 minutes.	Recovery drill with timed steps (TC-21)	MUST
NFR-05	Usability	Users able to reset password without help.	≥ 90% of test users complete reset unaided in ≤ 3 minutes and ≤ 5 steps.	Moderated usability test (TC-22)	SHOULD
NFR-06	Maintainability	Adding app does not require code changes in IdP.	Onboarding a new standards-compliant test app requires 0 IdP source code changes (configuration only).	Onboarding exercise with code diff check (TC-23)	SHOULD

3.4 Design Constraints

The architecture shall keep the identity provider and each application loosely coupled (standard protocols only, no shared database, no application-specific code inside the IdP) and each module cohesive (single responsibility: authentication, session management, access control, SSPR, audit, and adapters).

4. MoSCoW Prioritization

Category	Items Included	Engineering Rationale
Must Have	FR-01, FR-02, FR-03, FR-04, FR-06, FR-07, FR-08, FR-09, FR-10; NFR-01, NFR-02, NFR-03, NFR-04	Without these there is no working, secure SSO for the 9 standards-capable apps, or SPOF is unmanaged. FR-07 delivers 75% reset reduction.
Should Have	FR-05, FR-11; NFR-05, NFR-06	High value but workaround exists. FR-05 depends on unproven vendor adapter feasibility costing 45 person-days.
Could Have	C-01 Usage trend dashboard; C-02 Password-strength meter; C-03 Remember-this-device option	Valuable enhancements; only if schedule reserve remains inside the 16-week envelope.
Won't Have	W-01 Social login; W-02 Passwordless/biometric login; W-03 Replacing internal app authorization; W-04 App data migration; W-05 SSO beyond 12 apps	Explicitly out of scope for the semester deadline or outside problem parameters.

Summary Count: 13 Must Have (9 FR + 4 NFR), 4 Should Have (2 FR + 2 NFR), 3 Could Have, 5 Won't Have.

5. Requirements Traceability Matrix (RTM)

Every functional requirement links to at least one test case, and every non-functional requirement to a verification test. Expanded test cases (TC-01 through TC-23) are detailed in the Test Plan.

Req ID	Short Title	Priority	Test Case(s)	Verification & Test Focus
FR-01	Central authentication	Must	TC-01, TC-02	Valid login; invalid credentials with generic error
FR-02	SSO session & logout	Must	TC-03, TC-04	One login, three applications; logout ends all sessions
FR-03	Cloud federation	Must	TC-05	Valid assertion accepted; tampered/expired rejected
FR-04	In-house integration	Must	TC-06	Redirect to IdP; local direct login disabled
FR-05	Vendor integration	Should	TC-07	Adapter SSO works or exception formally recorded
FR-06	RBAC matrix	Must	TC-08, TC-09	Role-application decision table; role change in ≤ 5 min
FR-07	Self-service reset	Must	TC-10, TC-11	End-to-end reset; code expiry boundary (14/15/16 min) and single-use
FR-08	Failed-login logout	Must	TC-12, TC-13	Boundary 4/5/6 failed attempts; lock expiry and helpdesk unlock
FR-09	Session timeout	Must	TC-14	Boundary 29/30/31 minutes idle
FR-10	Audit logging	Must	TC-15, TC-16	Event records present; zero secrets or passwords in logs
FR-11	MFA privileged roles	Should	TC-17	Required for helpdesk/admin, not prompted for students
NFR-01	Login availability	Must	TC-18	Uptime probe against $\geq 99.9\%$ target
NFR-02	Security posture	Must	TC-19	TLS 1.2+, salted bcrypt hashes, cookie flags, zero high vulns
NFR-03	Response time	Must	TC-20	$p95 \leq 2.0s$ login; $\leq 1.0s$ extra per subsequent app access
NFR-04	Recoverability	Must	TC-21	$RTO \leq 30$ min, $RPO \leq 15$ min drill validation
NFR-05	Usability	Should	TC-22	90% unaided reset within 3 minutes and 5 steps
NFR-06	Loose coupling	Should	TC-23	Onboard new application with 0 IdP code modifications

Coverage & Completeness Verification: 11 of 11 functional requirements (100%) and 6 of 6 non-functional requirements (100%) map to at least one test case across the verification suite (23 test cases in total, TC-01 through TC-23). No test case exists without a parent requirement, ensuring zero dead verification effort.

Appendix A — Open Issues to Confirm

The following open issues represent design, deployment, and operational dependencies identified during requirements elicitation that require formal resolution during initial sprint execution.

#	Open Issue Description	Designated Owner	Downstream Impact
1	Total number of student and staff accounts, and peak concurrent logins at semester start	IT Head / Helpdesk	NFR-03 sizing & load simulation profile
2	Specific naming breakdown of 12 applications into groups (cloud/in-house/vendor)	Application Owners	FR-03 to FR-05 wave scheduling
3	Hosting model for OneLogin (on-premise vs. cloud) and standby redundancy arrangement	IT Head	NFR-01, NFR-04 high availability design
4	Feasibility of an adapter for each of the 3 vendor products, including licensing constraints	Lead Engineer	FR-05 feasibility gate & scope commitment
5	Budget allocation for software licenses, hosting, and SMS/email gateway services	Vice-Chancellor	Project procurement & communication SLAs
6	Formal governance confirmation of NFR security thresholds (5 attempts, 15-min lock, 30-min idle timeout)	IT Head, Security Lead	FR-08, FR-09, NFR-01 to NFR-06 policy rules

Resolution & Escalation Protocol

- **Issues 1 & 3 (Load Profile & Infrastructure):** Must be resolved by Milestone 2 (Core IdP Setup) to ensure hardware and cache clusters are sized for peak semester registration concurrency.
- **Issue 4 (Vendor Adapter Feasibility):** Time-boxed to a 3-day technical spike in Week 4. If legacy vendor products lack HTTP header injection hooks or reverse-proxy cookie support, they are formally logged as exceptions per FR-05 acceptance criteria.
- **Issue 6 (Security Parameters):** Baseline targets represent industry standards for higher education authentication and are enforced in staging pending any institutional overrides.

Document Baseline Status: With all 11 Functional Requirements, 6 Non-Functional Requirements, 23 Traceable Test Cases, and 6 Operational Open Issues cataloged, this specification represents the approved functional and quality baseline for project execution.